

SOC 2 Gap Assessment

Mock portfolio assessment - Security and Availability criteria

Purpose

This assessment evaluates a fictional mid-sized organization against selected SOC 2 Trust Services Criteria. It demonstrates control review, gap identification, remediation planning, ownership, and evidence expectations.

Executive Summary

Overall readiness: 68%. The organization has foundational security practices but needs stronger evidence retention, access recertification, vendor oversight, and incident-response testing before a formal examination.

Control Gap Matrix

Control	Current State	Gap	Rating	Remediation	Owner	Due
CC1.2 Governance	Policies approved informally	No annual board-level review evidence	Partial	Establish annual approval calendar and retain minutes	GRC Lead	2026-09-30
CC6.1 Logical Access	MFA and role-based access used	Quarterly access reviews not documented	Partial	Run quarterly certifications; retain sign-off and removals	IAM Manager	2026-08-31
CC6.2 Provisioning	Manager approval required	Termination deprovisioning may exceed 24 hours	Gap	Automate HR termination feed and SLA monitoring	IT Ops	2026-08-15
CC7.2 Monitoring	EDR and SIEM deployed	Alert triage metrics not reported	Partial	Create monthly detection KPI dashboard	SOC Manager	2026-10-01
CC7.4 Incident Response	Plan exists	No tabletop test in past 12 months	Gap	Conduct ransomware tabletop and track actions	Security Lead	2026-09-15
CC9.2 Vendor Risk	Questionnaires used for critical vendors	No centralized tiering or annual reassessment	Gap	Implement tiered TPRM process and review schedule	Vendor Manager	2026-11-01

Prioritized Roadmap

Priority	Action	Success Measure
1	Automate access termination and quarterly reviews	100% terminations within 24 hours; 100% quarterly certifications completed
2	Run incident-response tabletop	After-action report approved and all actions assigned
3	Formalize vendor tiering	All critical vendors scored and reassessed annually
4	Strengthen evidence management	Evidence repository contains owner, period, source, and approval metadata